FIAP

LET'S ROCK THE FUTURE

SECURITY MANAGEMENT

(VULNERABILITY AND RESPONSE)

Classificação: Uso Interno

APRESENTAÇÃO

JOSÉ RICARDO MACHADO

- Paulistano
- Formado em Redes de Computadores
- MBA em Gestão em Segurança da Informação
- Coordenador de Infraestrutura, Arquitetura e GRC no SOC da Embratel
- 16 anos de experiência em projetos de TI, Segurança, Conscientização e Gestão de Riscos e Compliance.
- Experiência em empresas de setor de tecnologia, varejo, telecom e cyber.

profjose.machado@fiap.com.br

APRESENTAÇÃO

FALE SOBRE VOCÊ...

- Seu nome
- Sua Idade
- Sua cidade/bairro
- Trabalha em qual empresa?
- Já trabalha na área? Qual TI / Dev/ Segurança?
- Qual seu principal objetivo nesse curso?

OBJETIVO DA DISCIPLINA

- Capacitar os alunos a definir o que é informação
- Como identificar as informações de acordo com a importância para o negócio
- Identificar a estrutura e a organização da Segurança da Informação na empresa
- Identificar e gerenciar os riscos de Segurança da Informação na empresa
- Entender a estratégias para gerenciamento de incidentes
- Entender os controles de segurança aplicáveis para os ativos de informação
- Teoria e prática sobre gestão de vulnerabilidades
- Entender a estratégias para gerenciamento de identidade e senhas
- Identificar os principais tipos de Engenharia Social
- Mostrar como criar um Programa de Conscientização
- Mostrar como criar campanhas de Ethical Phishing

EMENTA – 1° Semestre

Conteúdo Programático - 1TDCPV		
DISCIPLINA:	SECURITY MANAGEMENT (VULNERABILITY AND RESPONSE)	
CARGA HORÁRIA:	SEXTA - 2 H /SEMANA	
1º. Semestre		
Semana	CONTEÚDO	
1	**Apresentação do Professor e do Conteúdo** **Objetivo da disciplina** **Aula Inaugural, apresentação do plano de ensino.**	06/mar
1	Conceito e valor da informação (ISO 27001)	06/mar
2	Aspectos de confiabilidade da Informação (ISO 27001)	13/mar
3	Política de segurança (ISO 27001)	20/mar
3	**Check Point 01 - Construção de PSI**	20/mar
4	Conceitos de ameaças e riscos (ISO 27001)	27/mar
5	Não havera aula - Feriado de Paixão de Cristo	03/abr
6	Componentes da organização da segurança (ISO 27001)	10/abr
7	Gerenciamento de incidentes (ISO 27001)	17/abr
7	**Check Point 02 - Matriz RACI Resposta a Incidentes**	17/abr
7	Importância da ISO 27001	24/abr
8	Não havera aula - Emenda Feriado	01/mai
9	Medidas físicas, técnicas e organizacionais (ISO 27001)	08/mai
10	Legislação e regulamentação (ISO 27001) - 27001 e Privacidade	15/mai
10	**Check Point 03 - Mapeamento de dados pessoais**	15/mai
11	Segurança em Camadas (parte 1)	22/mai
12	**Provas semestrais - Cenario + Gestão de Riscos + Aplicações de Controles**	29/mai
13	Não havera aula - Emenda Feriado	05/jun
13	**Provas - DP**	11/jun
14	**Provas semestrais - Substitutivas**	19/jun
N/A	Não havera aula - Emenda Feriado	20/jun
15	Férias	01/jul

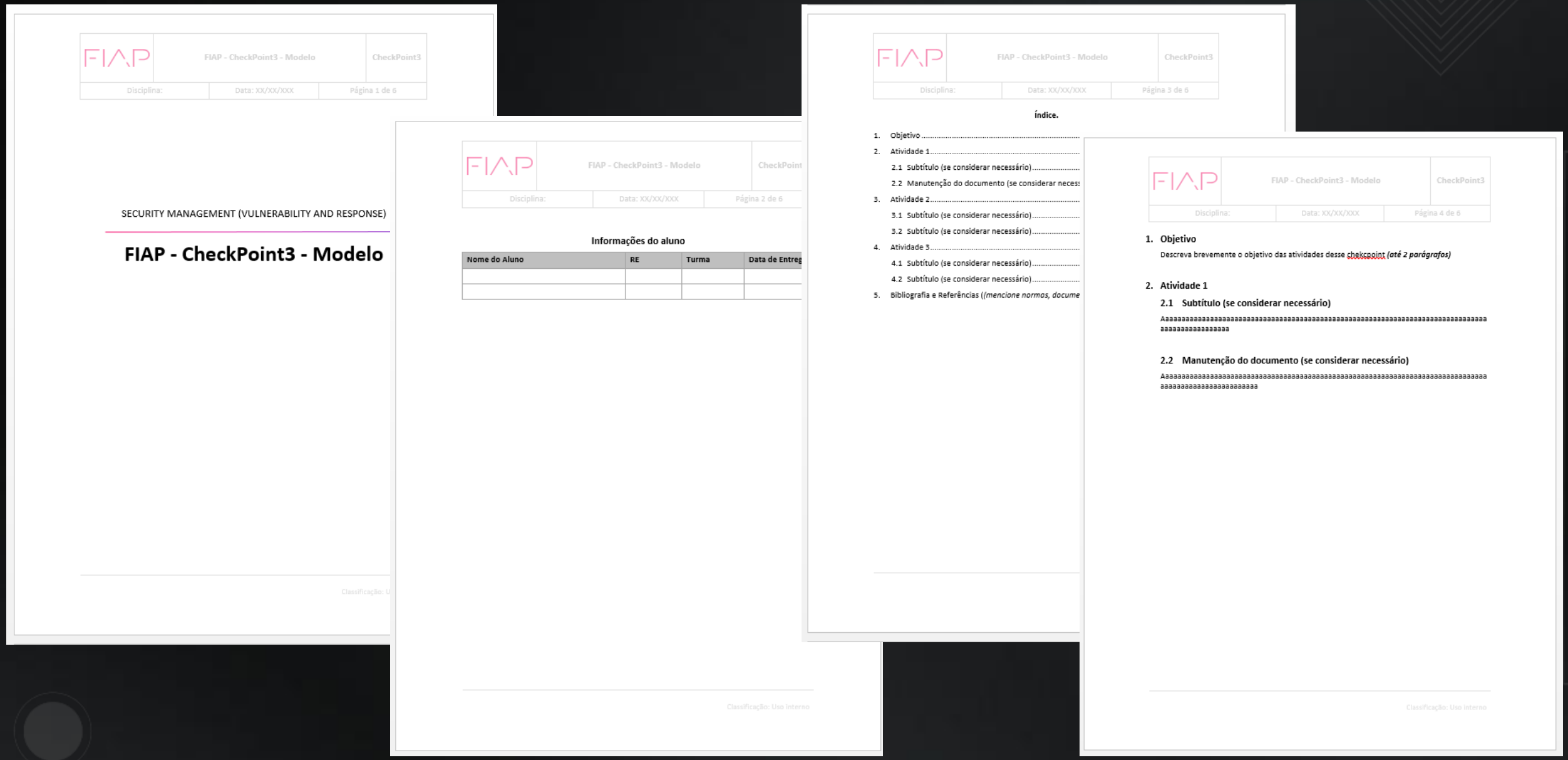
EMENTA – 2° Semestre

2º. Semestre	
1	Conscientização em Segurança da Informação
2	Estrutura de segurança cibernética do NIST (NIST CSF 2.0)
3	Processo de Gestão de vulnerabilidades
4	Principais tipos de vulnerabilidades
5	Ferramentas para gestão de vulnerabilidades
5	**Check Point 01 - Norma de Gestão de Vulnerabilidades**
6	Analise de vulnerabilidades de forma prática - parte 1
7	Analise de vulnerabilidades de forma prática - parte 2
7	**Check Point 02 - Mitigação de Vulnerabilidades**
8	Engenharia Social
9	Engenharia Social: prática - Phishing
10	Gerenciamento de identidade e acesso (Identidade Digital, SSO e Controle de acesso, Políticas, Armazenamento e Autenticação multifator)
11	Principais ameaças globais à Segurança da Informação
11	**Check Point 03 - Connstrução de uma simulação de Phishing**
13	**Provas semestrais - Periodo de aplicação das Semestrais Regulares e de DP - Global Solutions**
14	**Provas - DP - Período de vistas das Avaliações e aplicação das Avaliações Substitutivas Regulares e DP**
15	**Exames Finais**
16	**Vistas dos Exames Finais**
17	**Fechamento das atas de resultados finais**
18	**Término do ano letivo**

AVALIAÇÃO

Check Points	
Check Point 1	Construção de uma Política de Segurança
Check Point 2	Matriz RACI de Resposta à Incidentes
Check Point 3	Mapeamento de Dados Pessoais

Orientações para as atividades



FIAP | FIAP - CheckPoint3 - Modelo | CheckPoint3

Disciplina: | Data: XX/XX/XXX | Página 1 de 6

SECURITY MANAGEMENT (VULNERABILITY AND RESPONSE)

FIAP - CheckPoint3 - Modelo

Classificação: U

FIAP | FIAP - CheckPoint3 - Modelo | CheckPoint

Disciplina: | Data: XX/XX/XXX | Página 2 de 6

Informações do aluno

Nome do Aluno	RE	Turma	Data de Entreg

Classificação: Uso interno

FIAP | FIAP - CheckPoint3 - Modelo | CheckPoint3

Disciplina: | Data: XX/XX/XXX | Página 3 de 6

Índice.

1. Objetivo .....
2. Atividade 1 .....
   2.1 Subtítulo (se considerar necessário) .....
   2.2 Manutenção do documento (se considerar necess
3. Atividade 2 .....
   3.1 Subtítulo (se considerar necessário) .....
   3.2 Subtítulo (se considerar necessário) .....
4. Atividade 3 .....
   4.1 Subtítulo (se considerar necessário) .....
   4.2 Subtítulo (se considerar necessário) .....
5. Bibliografia e Referências ((*mencione normas, docume*

FIAP | FIAP - CheckPoint3 - Modelo | CheckPoint3

Disciplina: | Data: XX/XX/XXX | Página 4 de 6

1. Objetivo

Descreva brevemente o objetivo das atividades desse chekcpoint ***(até 2 parágrafos)***

2. Atividade 1

2.1 Subtítulo (se considerar necessário)

Aaa

FIAP

Prova Semestral

Individual e sem consulta

Questões de múltipla escolha

Cenários propostos, baseados em situações e casos reais

Realização de prova SUB somente com atestado médico. Cada caso será avaliado pela Coordenação. Aprovação não depende do professor.

FIAP

Chamada

- Realizado sempre no fim da aula
- Quem não responder ficará com falta
- Atestados devem ser enviados por e-mail para o professor
- Nenhuma aula da Graduação será gravada
- Importante participar de cada aula. Não há reposição.

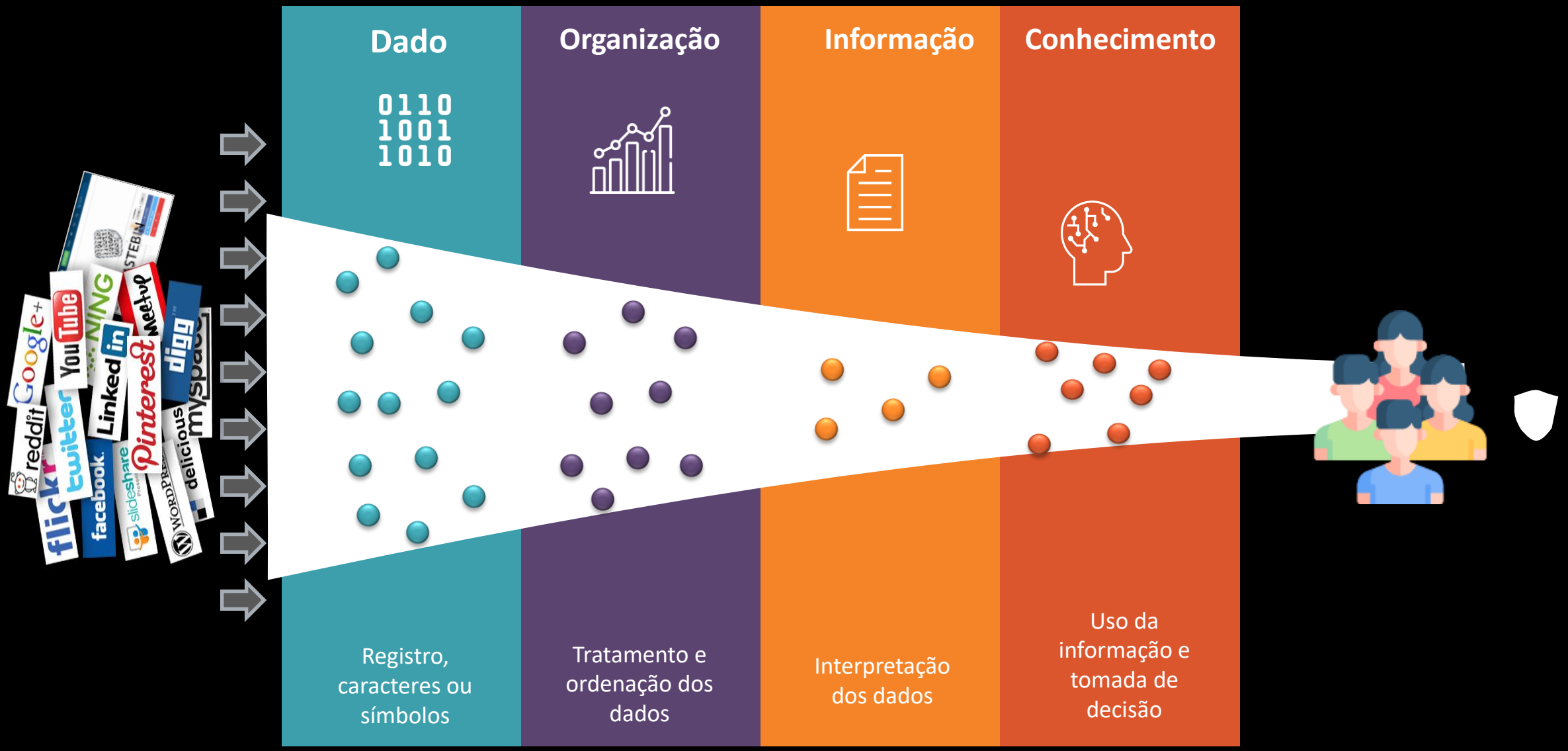
Dúvidas

Em caso de dúvidas, dificuldades ou qualquer assunto relacionado com essa disciplina, contatar diretamente o professor pelo e-mail **profjose.machado@fiap.com.br**

AULA 1

CONCEITO E VALOR DA INFORMAÇÃO

O que é Informação?



O que é Informação?

Dados

São artefatos brutos, quantitativos ou qualitativos, sem organização ou contexto.

Representam observações diretas, como números, símbolos, imagens ou registros, mas não possuem significado intrínseco.

Exemplos

Temperatura de 38°C em um sensor.

Sequência de letras: "A, B, C"

Número de acessos a um site: 1.200

Informação

Dados organizados, contextualizados e interpretados para transmitir significado.

Surge quando os dados são processados, filtrados e estruturados para responder a perguntas como "quem?", "o quê?", "quando?", "onde?"

Exemplos

A temperatura de 38°C no sensor X, às 15h, indica febre em um paciente

A sequência 'A, B, C' representa as notas de um aluno em três provas

1.200 acessos ao site ocorreram após uma campanha de marketing em julho

O que é Informação?

Conhecimento

A compreensão das relações entre informações, permitindo a aplicação prática.

Responde ao "como?" e ao "por quê?", combinando experiência, contexto e interpretação.

Exemplos

Saber que a febre de 38°C em um paciente com tosse pode indicar uma infecção respiratória.

Analisar que as notas "A, B, C" refletem o desempenho inconsistente do aluno em matemática.

Entender que os 1.200 acessos ao site estão 20% acima da média, graças a uma estratégia de redes sociais.

Sabedoria

A capacidade de aplicar conhecimento de forma ética, crítica e estratégica para resolver problemas complexos.

Envolve julgamento, valores e visão de longo prazo, respondendo ao "qual é o melhor caminho?".

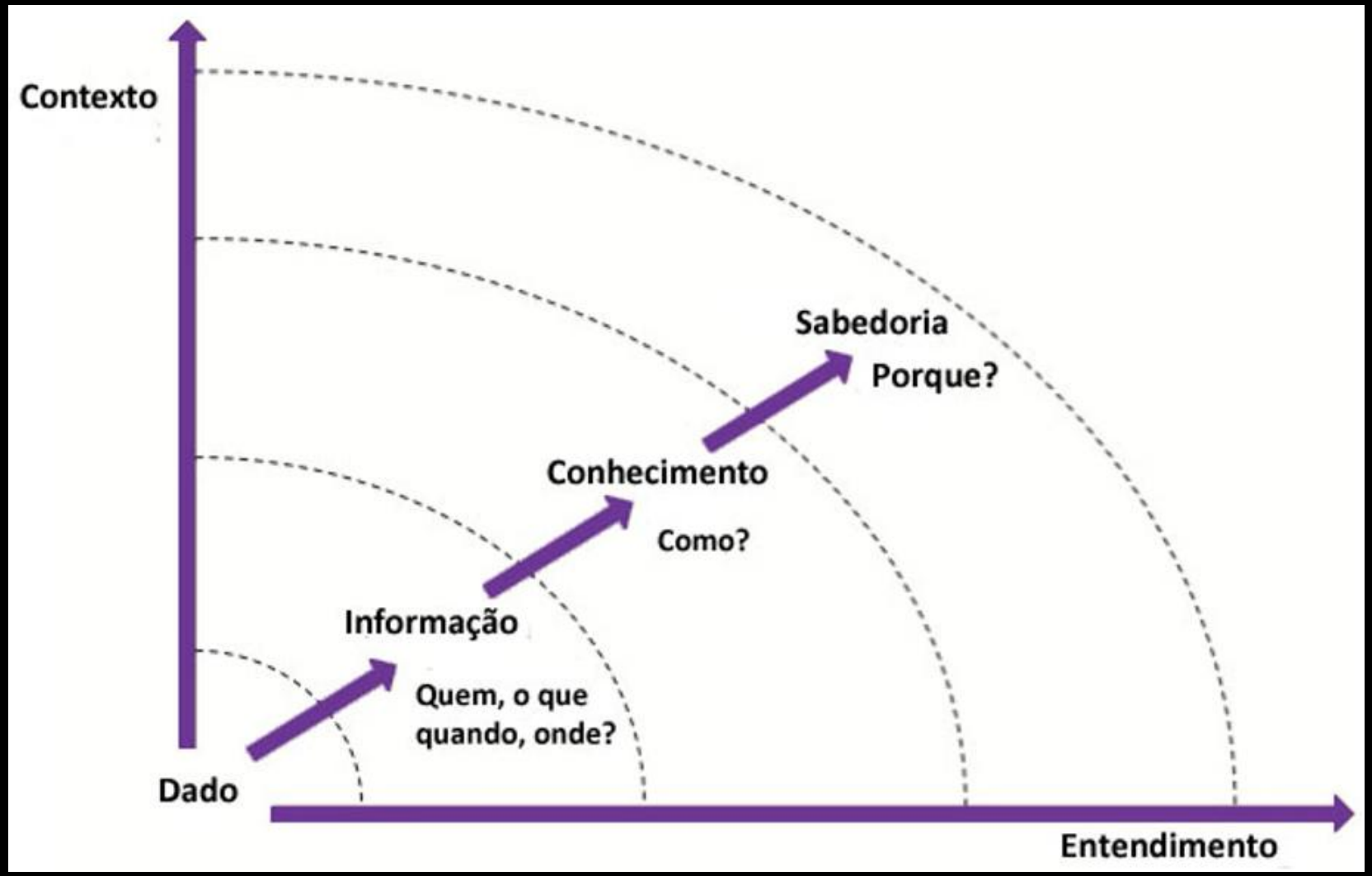
Exemplos

Decidir não tratar a febre de 38°C com antibióticos imediatamente, pois pode ser viral e o uso indiscriminado gera resistência.

Orientar o aluno com notas "A, B, C" a focar em aulas de reforço, considerando seu deseepnho nas ultimas provas.

Alocar mais recursos para a campanha que gerou os 1.200 acessos, mas avaliar o Retorno do investimento a longo prazo.

O que é Informação?



Fonte: ITIL v4

O que é Informação?

3 ovos

1 copo de leite

2 xícaras de açúcar

½ copo de óleo

3 colheres de farinha de trigo

1 colher de fermento em pó

2 xícaras de fubá

É um dado

É mais um dado

Agora temos diversos dados

Mas sem contexto

O QUE?

Receita de bolo de fubá

Agora temos um contexto

Temos a informação

COMO?

Modo de preparo da receita

Agora temos conhecimento

POR QUE?

Orientações práticas

Sabedoria

O que é Informação?

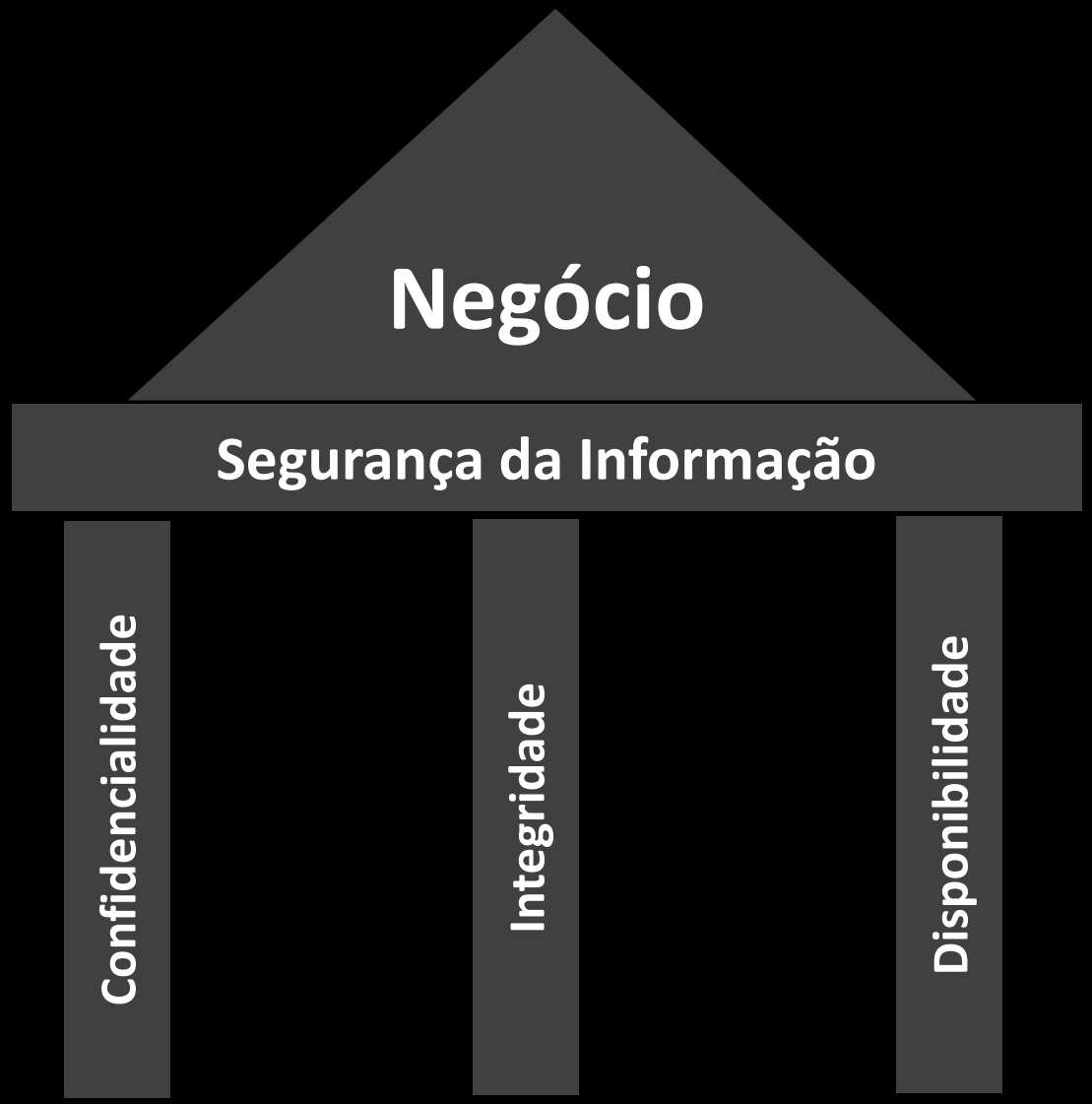
Ana	Manhã	São Paulo
Bruno	Noite	Osasco
Carla	Noite	Rio de Janeiro
Douglas	Manhã	Belo Horizonte

FIAP

Ativo é qualquer elemento que tem valor para uma organização

ATIVOS

FIAP



Garantir a continuidade do negócio, minimizando os riscos e maximizando o retorno sobre os investimentos e as oportunidades de negócio.

Alinhamento Estratégico

Fluxo correto da Informação

FIAP

Garantir a Disponibilidade da Informação

Impedir que um ativo seja comprometido ou torna-se inacessível caracterizando a perda da disponibilidade. Por exemplo, a perda de acesso a um site importante.

Continuidade operacional

Impedir downtime em sistemas críticos (ex: e-commerce, SaaS) causa perda de receita e insatisfação do cliente.

Resiliência a ataques

Ransomware e DDoS podem paralisar operações por dias (ex: Colonial Pipeline, 2021).

Reputação

Serviços indisponíveis repetidamente afastam clientes e parceiros.

Garantir a Confidencialidade da Informação

Impedir que um ativo seja acessado por uma parte não autorizada (pessoa, programa ou computador), caracterizando um ataque contra a confidencialidade.
Por exemplo, acesso ou cópia não autorizada de arquivos ou programas.

Proteção de segredos comerciais

Dados como estratégias de mercado, propriedade intelectual ou planos de produtos podem definir a vantagem competitiva de uma empresa.

Conformidade legal

Leis como a LGPD (Brasil) e GDPR (Europa) exigem proteção de dados pessoais. Violações resultam em multas e perda de reputação.

Garantir a Integridade da Informação

Impedir que um ativo seja modificado por um agente não autorizado.
Por exemplo: alteração do conteúdo de uma planilha ou inserção de código malicioso em um documento.

Fraude e manipulação

Alterações não autorizadas em transações bancárias ou registros contábeis podem resultar em perdas diretas.

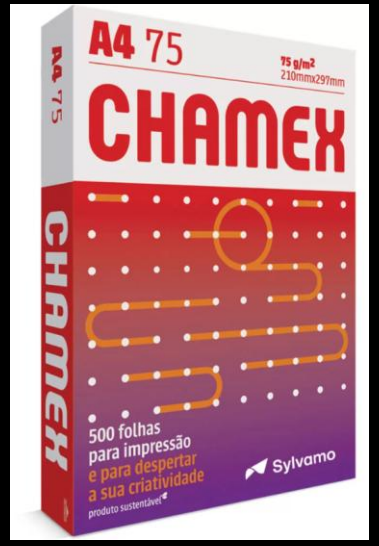
Consequências de perda da Matriz CID

Confidencialidade	**Causa:** APIs mal configuradas, código aberto, invasão.	**Efeito:** Exposição de dados, roubo de identidade, multas colosais (Equifax, Pix).
Integridade	**Causa:** Falha de sincronização, modificação maliciosa.	**Efeito:** Perda da exatidão dos dados, execução de espiões (Itaú, SolarWinds).
Disponibilidade	**Causa:** Atualizações sem teste, Ransomware.	**Efeito:** Paralisação total de infrastruturas críticas e serviços essenciais (CrowdStrike, WannaCry).

Uma pequena discussão.

Se você perde algum desses itens qual você sentiria mais prejudicado?

Valor Intrínseco



Meta

Microsoft

Apple®

amazon

Google

UBER

Uber, a maior empresa de táxi do mundo, não tem carros.

Facebook, a mídia mais popular do mundo, não cria conteúdo.

Alibaba.com

Alibaba, a varejista mais valiosa do mercado, não tem estoque.

E Airbnb, a maior provedora de hospedagem do mundo, não possui qualquer imóvel.

airbnb

Ciclo de Vida Informação

A informação precisa ser protegida em todas as etapas de seu ciclo de vida de acordo com o seu VALOR para o negócio.

Contextualização do Negócio

Para a proteção adequada de uma empresa ou instituição é fundamental conhecer o negócio

Conhecer o negócio
O que a empresa faz?
Quais são seus produtos?
Quem são seus clientes

Conhecer o setor de atuação
É uma empresa pública, privada ou de capital misto?
É um setor regulado? Quais as leis e regulamentações aplicáveis?
Como definir políticas e controles para manter o nível de conformidade?

Conhecer as "jóias das coroas"
Quais ativos e informações são críticas?
Qual o impacto do comprometimento dessas informações?
Como monitorar adequadamente estes ativos para detectar uma violação às politicas definidas?

Gestão de Riscos e Continuidade do negócio
Quais os riscos que os ativos representam ao negócio, de acordo com a probabilidade e impacto?
Qual o plano de ação definido para garantir que o negócio continue operando mesmo diante da materialização do risco?

OBRIGADO

profjose.machado@fiap.com.br

FIAP

Copyright © 2023 | Professor JOSÉ RICARDO MACHADO

Todos os direitos reservados. Reprodução ou divulgação total ou parcial deste documento, é expressamente proibido sem consentimento formal, por escrito, do professor/autor.

FIAP